

SEGURIDAD INFORMATICA

UNIVERSIDAD POLITÉCNICA --- DE SAN LUIS POTOSÍ

NOMBRE DEL ALUMNO: Leonardo Serrano Zermeño

MATRICULA: 177301

FECHA: 13/02/2025

NUMERO DE ACTIVIDAD: 5

TITULO DE LA ACTIVIDAD: Cartografiando el pentesting

Actividad 05: Cartografiando el pentesting: análisis comparativo de metodologías de seguridad informática.

Introducción

El propósito de esta actividad es el de analizar y comparar de manera estructurada las principales metodologías y marcos de referencia utilizados en pruebas de penetración y evaluación de seguridad informática, con el fin de que el estudiante comprenda sus enfoques, objetivos contextos de aplicación y alcances técnicos, fortaleciendo su criterio para seleccionar y aplicar la metodología mas adecuada para distintos escenarios de seguridad.

Desarrollo

En esta actividad, se realizan distintos cuadros comparativos, los cuales tienen la intención de ser integrados en uno solo.

Metodología	Descripción	Fases	Objetivo	Escenarios	Orientación
MTRE ATT&CK	Marco de conocimiento global basado en tácticas y técnicas de adversarios reales	La metodología es no lineal, se organiza en 14 tácticas. Entre ellas: Acceso inicial, Persistencia y exfiltración	Detectar las técnicas de ataque y emulación de adversarios	Centros de operaciones de seguridad (SOC), Threat hunting y Red Teaming	Defensa / Ofensiva
OWASP WSTG	Es una guía exhaustiva para evaluar la seguridad de aplicaciones y servicios web.	12 categorías técnicas, entre ellas: Gestión de identidad, Autenticación, pruebas de API.	Pruebas técnicas de seguridad específicas para software web.	Auditorias de aplicaciones web, entornos Cloud y desarrollo de software seguro.	Ataque / Evaluación
NIST SP 800-115	Guía técnica para planificar y realizar evaluaciones de seguridad informática.	1. Planificación, 2. Ejecución, 3. Post-ejecución, 4. reporting	Evaluación de controles y validación de políticas de seguridad.	Sectores gubernamentales y organizaciones reguladas (HIPPA, PCI DSS)	Evaluación
OSSTMM	Manual basado en métricas para la verificación	1. introducción, 2. interacción, 3. inundación,	Medición y validación de controles mediante	Seguridad física, redes inalámbricas, telecomunica-	Evaluación (Métrica)

	de la seguridad operacional	4. análisis, 5. Reporte (STAR)	métricas científicas.	ciones y factor humano.	
<i>PTES</i>	Estándar que define el proceso de negocio y ejecución de un pentest de alta calidad.	1.Pre-engagement, 2. Intelligence gathering, 3. Threat modeling, 4. Vulnerability analysis, 5. Exploitation, 6. Post-exploitation, 7. Reporting	Estandarizar el ciclo de vida completo de una prueba de penetración comercial	Consultoría profesional de pentesting y Red Teaming Corporativo	Ataque / Ofensiva
<i>ISSAF</i>	Marco integral que vincula herramientas técnicas con procesos de auditoría.	1.Planeacion, 2. Evaluación (9 capas de prueba) 3. Reporte y tratamiento.	Estandarizar evaluaciones técnicas profundas de sistemas de información	Auditorías detalladas de infraestructura, SO y bases de datos	Ataque / evaluación

A continuación, se muestra el complemento de la tabla anterior, conteniendo alguna información acerca de las empresas que están detrás de cada una de las metodologías mostradas anteriormente.

<i>Metodología</i>	<i>Autores</i>	<i>Fuente</i>	<i>Certificaciones</i>	<i>Versiones</i>
<i>MITRE ATT&CK</i>	MITRE Corporation	attack.mitre.org	MITRE ATT&CK Defender (MAD)	v16.1 (Actualización constante)
<i>OWASP WSTG</i>	OWASP Foundation	owasp.org/WSTG	OSWA (Offensive Security), GWAPT (SANS)	v4.2 (Estable) / v5.0 (Vigente)
<i>NIST SP 800-115</i>	NIST (Dpto. de comercio EE. UU)	csrc.nist.gov	Referenciada en CISA, CISSP y CEH	Versión original (Vigente por estándares federales)
<i>OSSTMM</i>	ISECOM (Pete Herzog)	isecom.org/OSSTMM	OPST, OPSA, OPSE	v3.0 (v4.0 en fase de implementación)

<i>PTES</i>	Comunidad técnica (Rapid 7, etc.)	pentest-standard.org	Adoptada por OSCP, GPEN y CPENT	Estándar comunitario (Vigente)
<i>ISSAF</i>	OISSG (Open InfoSystems SG)	oissg.org	Histórica; referenciada en CISM y CISA	v0.2.1 (Marco de referencia técnica)

Bibliografías

- MITRE. (2026). MITRE ATT&CK® Matrix for Enterprise. Recuperado de <https://attack.mitre.org/>
- OWASP Foundation. (2026). Web Security Testing Guide (WSTG). Recuperado de <https://owasp.org/www-project-web-security-testing-guide/>
- National Institute of Standards and Technology. (2026). Technical Guide to Information Security Testing and Assessment (SP 800-115). Recuperado de <https://csrc.nist.gov/>
- ISECOM. (2026). The Open-Source Security Testing Methodology Manual (OSSTMM). Recuperado de <https://www.isecom.org/>
- PTES Team. (2026). The Penetration Testing Execution Standard. Recuperado de <http://www.pentest-standard.org/>
- OISSG. (2026). Information Systems Security Assessment Framework (ISSAF). Recuperado de <https://oissg.org>